

Estructura del Reporte (ISO 27001)

Título del Reporte

Explotación de Vulnerabilidad SQL Injection en Aplicación DVWA

Introducción

El día de hoy, sábado 30 de mayo de 2026, se realizaron pruebas de seguridad de la información sobre la plataforma Damn Vulnerable Web Application (DVWA) montada en un servidor Debian, con el fin de evaluar la resiliencia del sistema ante ataques a nivel de aplicación bajo los lineamientos de la norma ISO 27001.

Descripción del Incidente

Se identificó una falla de validación de entradas en el componente de consulta de usuarios ("User ID") de la sección SQL Injection. La aplicación no sanitiza adecuadamente los caracteres especiales (comillas simples) introducidos por los usuarios, lo que permite inyectar comandos SQL maliciosos directamente hacia el motor de la base de datos MariaDB.

Proceso de Reproducción

Se accedió a la sección SQL Injection de la aplicación web.

En el campo "User ID" se introdujo el payload malicioso: 1' OR '1'='1.

Se presionó el botón "Submit".

The screenshot shows the DVWA (Damn Vulnerable Web Application) interface. The browser address bar displays the URL: `http://localhost/DVWA/vulnerabilities/sql/?id=1'+OR+'1'='1&Submit=Submit#`. The DVWA logo is visible at the top. On the left, a sidebar menu lists various security modules, with "SQL Injection" highlighted in green. The main content area is titled "Vulnerability: SQL Injection" and contains a "User ID:" input field followed by a "Submit" button. Below the input field, the application displays the results of the query in red text, showing that the malicious payload successfully retrieved user information:

```
ID: 1' OR '1'='1
First name: admin
Surname: admin

ID: 1' OR '1'='1
First name: Gordon
Surname: Brown

ID: 1' OR '1'='1
First name: Hack
Surname: Me

ID: 1' OR '1'='1
First name: Pablo
Surname: Picasso

ID: 1' OR '1'='1
First name: Bob
Surname: Smith
```

Below the results, there is a "More Information" section with a list of links:

- https://en.wikipedia.org/wiki/SQL_injection
- <https://www.netsparker.com/blog/web-security/sql-injection-cheat-sheet/>
- https://owasp.org/www-community/attacks/SQL_injection
- <https://bobby-tables.com/>

El sistema alteró la consulta SQL original y devolvió la lista completa de usuarios registrados sin autorización previa.

Impacto del Incidente

El impacto es Alto. Un atacante puede comprometer la confidencialidad total de los datos (extrayendo contraseñas, información sensible) e incluso comprometer la integridad (modificando o borrando datos) o la disponibilidad del servidor mediante comandos avanzados de inyección.

Recomendaciones

¿Cómo se soluciona? (Aportes de mitigación):

- Implementar Consultas Preparadas (Prepared Statements) o consultas parametrizadas en el código PHP para separar los datos de las instrucciones SQL.
-
- Utilizar funciones de sanitización de entradas de texto.
-
- Aplicar el principio de menor privilegio en MariaDB para que el usuario web no tenga permisos de administrador sobre todo el motor de base de datos.

Conclusión

La detección temprana de esta vulnerabilidad demuestra la importancia de realizar auditorías continuas y cumplir con los controles de seguridad del ciclo de vida del desarrollo de software (A.14 de la ISO 27001) para evitar la fuga de información confidencial en entornos productivos.